内存签名检测已死？深入研究 Dittobytes

原创 老鑫安全 老鑫安全 2025年09月09日 09:19 四川

> 无论你如何打包、混淆或加密恶意软件，它最终总要在计算机内存中运行——这是所有规避技术的根本软肋

绕过安全产品是许多攻击性安全活动的一个非常重要的部分。当前各种免杀工具（如打包器、编码器和混淆器）中使用的大多数免杀技术都严重依赖于在 RWE 内存区域上运行的自修改代码。

然而，根据当前安全产品的检测能力，此类规避尝试很容易被内存分析模块捕获。原因在于所有这些方法都有一个共同的弱点：**恶意代码最终必须在内存中以明文形式存在**，才能被CPU执行。

这正是内存签名检测技术的理论基础——在恶意软件解压、解密或解码后，在内存中捕捉其特征进行检测。然而，一种名为DittoBytes的新型**变形恶意软件**正在彻底改变这场游戏规则。

Deoptimizer：二进制层的"改头换面"

为了避免被检测到而手动修改shellcode或从头编写新代码，都是一项永无止境的工作。早在之前Ege Balci开发的Deoptimizer提供了一个优雅的解决方案。

这个工具能够获取任何二进制形式的shellcode，通过**去优化技巧转换指令**，保留其原有功能，同时使代码变得独一无二，从而显著增加分析难度

其核心技术包括：

- **指令等价替换**：将简单指令替换为功能相同的复杂指令序列

- **控制流扰乱**：在不改变逻辑的前提下重组代码块结构
- **垃圾代码插入**：添加不影响执行的冗余指令

这种方法能轻松绕过基于原始字节序列的静态哈希和模式匹配签名

参考视频：https://www.bilibili.com/video/BV1WEadz8E7K/

DittoBytes：源码级的"脱胎换骨"

在Deoptimizer的基础上，DittoBytes更进一步，实现了真正的变形编译技术。这个项目可以将C++和C代码变形交叉编译为PIC、BOF和EXE格式，其创新性体现在：

- **源码级变形**：在编译过程中实现代码的彻底重构
- **完全随机化**：每次编译都会生成独一无二的二进制代码
- **跨平台支持**：支持生成位置无关代码（PIC）、信标对象文件（BOF）和可执行文件（EXE）

像 Dittobytes 这样的变形编译器将迫使EDR专注于运行时分析和检测行为异常，而不是依赖静态签名。而传统的EDR产品依赖静态签名和行为规则库，但在面对真正的变形技术时往往力不从心。

企业级防御新选择：哨兵EDR

面对日益复杂的 evasion 技术，企业需要更先进的防护方案。**哨兵EDR** 采用新一代行为分析引擎，专注于：

- **实时内存行为监控**：不依赖静态签名，深度分析代码执行行为
- **AI驱动的异常检测**：基于机器学习识别偏离正常模式的活动
- **跨平台防护**：全面支持Windows、Linux、macOS系统
- **零信任架构**：默认不信任任何进程，实现最小权限原则